

FUUdelivery (fuuphp) — resumo para a próxima IA

Dono: Marcos · Repositório: github.com/MarcosPavanBR/fuuphp (branch `main`, histórico reduzido a 1 commit em 28/09/2026) · Data: 28/09/2026

Regras do Marcos (valem sempre):

- Stack fixa: Svelte 5 + Bootstrap, PHP 8.4 (PDO, prepared statements), PostgreSQL 16 + `pg_cron`, Cloudflare, Mercado Pago, ESC/POS. **Nunca Go, nunca AbacatePay.**
- Nenhuma biblioteca, SDK ou serviço novo sem autorização do Marcos. Decisões de negócio: perguntar, não supor.
- Produção falha fechado** (`lib/core/production_guard.php` + `bin/check_production.php`): faltou segredo ou há modo simulado = não sobe.
- Segredos só em variável de ambiente / `.env` do servidor (600, fora do git). Nunca no front, nunca em commit.
- Comprovantes de pagamento e documentos de entregador nunca são públicos.
- Testes só em cópia do banco; nunca rodar `down` em produção. "Evidência ou não existe; rode, não imagine."
- Documentar e comentar tudo (em português). Commit e push ao terminar. Nenhum nome de modelo de IA em commit.
- Marcos quer execução direta, sem parar pra oferecer trabalho técnico, e **economia de tokens**. Ações que custam dinheiro ou são externas: confirmar.

1. O que é o sistema

Plataforma de delivery com 4 apps Svelte (`web/`): cliente (PWA, `index.html`), painel da loja (`painel.html`), entregador (`entregador.html`) e admin da plataforma (`admin.html`). API PHP em `api/v1/<área>/<ação>.php` (130 rotas, catálogo em `docs/API.md`), regras em `lib/`, tarefas em `bin/`. Banco: 48 migrações em `db/migrations` (65 tabelas, mapa em `docs/DATABASE.md`), papéis `app_rw` (API, sujeito a RLS), `app_ro`, `migrator`. 7 tarefas no `pg_cron` (Pix vencido, loja abre/fecha, repasse de terça, retenção LGPD etc.). 54 decisões registradas em `docs/decisions/`.

Funcionalidades prontas: pedido completo, pagamento Mercado Pago (cartão, cartão salvo, Pix automático) + Pix manual com comprovante + dinheiro + maquininha; livro-razão (ledger) só de inserção, repasse semanal (netting), estornos com executor, cupons (plataforma e loja, com teto), fidelidade, gorjeta, avaliações; dispatch com rodadas e raio crescente, acompanhamento ao vivo (SSE via LISTEN/NOTIFY); login OTP por SMS (Twilio), parceiros com senha; admin com TOTP obrigatório; push web (VAPID); impressão ESC/POS; cidades/fusos; banners; favoritos; LGPD (termos, exportar/apagar conta); candidatura de entregador com documento cifrado.

2. O que foi feito nesta rodada (setembro/2026)

Auditoria DevSecOps (decisões 47–51)

- Corrida no refresh token corrigida (UPDATE condicional); refresh agora em **cookie HttpOnly** `fuu_rt_<app>` (fora do `localStorage`).
- Pagamento que chega atrasado (pedido já cancelado) vira estorno automático (`late_payment`, migração 045); pagamento trava o pedido durante a chamada ao MP.
- 15 índices medidos (046); leitura tipada de toda entrada; matriz de autorização testada.
- Pool PHP-FPM separado pro SSE, máx. 3 conexões por usuário; TOTP do admin obrigatório em produção.
- Backup cifrado com GPG, instalado em `/usr/local/sbin`; `deploy.sh --migrate`; logs de erro em JSON.
- Documentos de entregador cifrados em disco (`DATA_ENCRYPTION_KEY`); fila de candidaturas no admin com nota de revisão (047).

- CI vermelho por aviso Deprecated do PHP 8.4 e JIT do xdebug: corrigido.

Hospedagem Supabase + Render (decisão 52)

- Dockerfile (PHP-FPM 8.4 + Nginx num contêiner), deploy/render/ (nginx com IP real via X-Forwarded-For + faixas Cloudflare, dois pools FPM, start.sh que recusa subir sem disco montado ou sem check_production, jobs.sh fazendo o papel do cron), render.yaml (Blueprint: Docker, Virginia, Starter, disco 5 GB em /var/fuuphp/storage, health check).
- lib/core/db.php: DATABASE_URL aceita ?sslmode= e senha codificada na URL.
- Job de CI render-image: constrói a imagem e sobe em modo produção (verde).
- Guia passo a passo: docs/SUPABASE_RENDER.md.
- Pix: só copia-e-cola (decisão do Marcos, sem biblioteca de QR).

Supabase — projeto fuuphp (criado e configurado)

- Ref vkhwvbjhyawoocisuux, região us-east-1, organização ligada à Vercel.
- 48 migrações aplicadas, 65 tabelas, 7 jobs pg_cron; deploy/supabase/lockdown.sql aplicado (anon/authenticated sem acesso; search_path dos papéis com extensions).
- Bucket avatars: leitura pública, 1 MB, só JPEG, sem política de escrita (só o servidor grava com SUPABASE_SERVICE_KEY).

Foto de perfil (migração 048)

- lib/storage/avatars.php + api/v1/profile/avatar.php (POST/DELETE; GET só no modo disco). Imagem validada pelo conteúdo, quadrada, 256 px, JPEG sem EXIF. Sem SUPABASE_URL → disco.
- Tela Editar perfil com adicionar/trocar/remover foto; avatar_url em profile/show.php; CSP libera *.supabase.co só em img-src.
- Teste tests/smoke_avatar.sh no CI. Não testado contra o Supabase real (falta a chave secreta).

Repositório

- Histórico reduzido a 1 commit (varredura: nenhum segredo nos 97 commits antigos). .gitignore corrigido (/storage/ só na raiz).

3. O que falta

Item	Quem	Detalhe
Tornar o repositório privado	Marcos	GitHub > Settings > Danger Zone > Change visibility. A sessão não tinha permissão.
Apagar execuções antigas do CI / purge de commits antigos	Marcos	Aba Actions (Delete workflow run); suporte do GitHub para purge.
Criar o serviço no Render	Marcos (+IA)	Conta atual pede cartão (erro 402). Marcos vai tentar outra conta. Caminho: projeto > New > Blueprint > repo fuuphp. Dar acesso do Render ao repo privado.
Segredos no Supabase	Marcos	Desligar Data API; ALTER ROLE app_rw/migrator/app_ro PASSWORD '...'; criar admin fundador com bin/bootstrap_admin.php.
Variáveis no Render	Marcos	DATABASE_URL (pooler de sessão 5432: app_rw.vkhwvbjhyawoocisuux@aws-0-us-east-1.pooler.supabase.com, sslmode=require), SUPABASE_SERVICE_KEY, DATA_ENCRYPTION_KEY, Mercado Pago (produção), Twilio, VAPID_SUBJECT, PUBLIC_ORIGIN.

Webhook Mercado Pago, domínio, Cloudflare	Marcos	Webhook: <code>https://<domínio>/api/v1/payments/webhook_mercadopago.php</code> . CNAME para o onrender.com, SSL Full (strict).
Supabase antigo "delivery" (sistema Go)	Marcos decide	45 tabelas sem RLS: a chave anon lê/altera usuários, tokens, carteiras. Corrigir (ENABLE ROW LEVEL SECURITY) ou desligar o projeto. Não foi mexido.
PHPStan + gitleaks no CI	IA	Autorizados; versão fixada e checksum; nível com 0 erros ou baseline.
Testes unitários das regras de dinheiro	IA	Runner PHP puro (sem biblioteca): <code>refund_plan</code> , <code>refund_payer</code> , <code>coupon_discount</code> , <code>money_input</code> , <code>refund_with_fee</code> .
Login por e-mail	Marcos decide	Precisa escolher provedor de e-mail (Twilio não manda e-mail); hoje o app esconde a opção.
Teto de sanidade / prazo da maquininha	—	Ficam no padrão até o Marcos mudar.

4. Como trabalhar no projeto

- Banco local: `docker compose up db` (Postgres 16 + `pg_cron`) ou PostgreSQL local; `DATABASE_URL=... bash db/migrate.sh up`. Produção: só `db/migrate.sh from N`.
- Testes: 41 suítes `tests/smoke_*.sh` (cada uma sobe um PHP embutido numa porta própria; precisa `DATABASE_URL` e `API_DATABASE_URL` como `app_rw`). Front: `cd web && npm test && npm run build`.
- Antes de commitar: `php bin/generate_api_catalog.php --check`, `php bin/generate_db_map.php --check`, `php bin/check_front_routes.php`. O CI (`.github/workflows/ci.yml`) roda tudo + round-trip de migrações + imagem Docker.
- Documentos-chave: `README.md`, `docs/GO_LIVE.md` (VPS), `docs/SUPABASE_RENDER.md`, `docs/SECURITY.md`, `docs/OPERATIONS.md`, `docs/decisions/`.